

SIMATS ENGINEERING

DEPARTMENT OF INFORMATION TECHNOLOGY

ETHICAL HACKING (ITA14) — ASSESSMENT TOOL 2 (CO4)

COMPREHENSIVE VULNERABILITY ASSESSMENT REPORT

Name:Aakash R(192524462)

Course Outcome	CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.
Rubric Mapping	Incident Background (20M) Vulnerability Identification (20M) Risk & Impact Analysis (20M) Security Recommendations (20M) Report Presentation (20M)

Case Study 1: TJX Companies Wireless Network Breach (2005–2007)

1. Incident Background & Technical Context

Between 2005 and 2007, attackers (led by Albert Gonzalez) exploited weak WEP encryption at a Marshalls store in Miami, Florida, intercepting payment transactions and pivoting across TJX's international retail infrastructure to compromise over 45 million credit/debit card numbers.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Obsolete Encryption	Continued deployment of 802.11b WEP with weak 24-bit IVs and RC4 stream cipher.
Missing Authentication	Static pre-shared WEP keys without individual user/device 802.1X enterprise authentication.
Flat Network Architecture	Inadequate network segmentation allowing direct bridging from store APs to central corporate databases.
Unencrypted Payment Data	Transmission and temporary storage of full magnetic stripe (Track 2) data in plaintext.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: Critical. Resulted in over \$170 million in fines, settlements, and remediation costs, massive cardholder fraud, severe reputational damage, and major FTC regulatory enforcement.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
-------------------	--

WPA2/WPA3 Enterprise	Deploy 802.11ac/ax with WPA3-Enterprise using AES-CCMP/GCMP-256 and individual 802.1X EAP-TLS certificates.
PCI DSS Compliance	Enforce strict Cardholder Data Environment (CDE) segmentation via firewalls and tokenization/P2PE.
WIDS/WIPS Deployment	Deploy dedicated sensor radios to detect rogue APs, packet sniffing, and unauthorized wireless bridging.

Case Study 2: Lowe's Wireless Network Intrusion (2003)

1. Incident Background & Technical Context

In 2003, attackers drove into a Lowe's parking lot in Southfield, Michigan, compromised the store's unsegmented wireless network, and pivoted across wide-area network (WAN) links to multiple nationwide retail stores attempting to deploy packet sniffers on Point-of-Sale (POS) systems.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Insecure Wireless Boundary	Unrestricted wireless signal coverage extending into public parking zones without directional shielding.
Missing Network Isolation	Zero network segmentation between retail POS terminals and in-store wireless inventory systems.
Lack of Inter-Store Firewall Controls	Open corporate WAN allowing local store compromises to propagate nationwide.
Weak POS Access Controls	Unrestricted administrative access to POS terminals without integrity verification.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: High. Attempted systematic installation of credit card interception malware across nationwide retail chains, highlighting the risk of flat inter-branch connectivity.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
POS Network Segmentation	Place all POS terminals in isolated, strictly firewalled VLANs with default-deny ingress/egress rules.
Zero-Trust Inter-Branch Routing	Enforce next-generation firewalls (NGFW) and microsegmentation across all WAN connections.
Centralized IAM & PAM	Deploy centralized Privileged Access Management (PAM) with Multi-Factor Authentication (MFA).

Case Study 3: Firesheep and Public Wi-Fi Session Hijacking (2010)

1. Incident Background & Technical Context

In 2010, the release of the Firesheep Firefox extension demonstrated passive sidejacking on open public Wi-Fi networks by intercepting unencrypted HTTP session cookies over the airwaves, allowing unauthenticated account takeovers on major web platforms.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Open Unencrypted Wi-Fi (802.11 Open)	Lack of over-the-air link encryption allowing promiscuous packet sniffing.
Partial TLS / Insecure Session Cookies	Web applications encrypting only login credentials while transmitting subsequent session cookies over cleartext HTTP.
Missing Cookie Security Flags	Failure to set 'Secure', 'HttpOnly', and 'SameSite=Strict' flags on session cookies.
No Client Isolation	Public APs allowing peer-to-peer traffic between connected wireless clients.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: High. Widespread automated account takeover of social media, email, and corporate accounts on open public Wi-Fi.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
HTTPS Everywhere & HSTS	Mandate HTTP Strict Transport Security (HSTS) with long max-age and preloading.
Wireless Client Isolation	Enable Client/AP Isolation on public wireless controllers to prevent peer-to-peer snooping.
OWASP Cookie Hardening	Enforce Secure, HttpOnly, and SameSite attributes on all session identifiers.
VPN & Opportunistic Wireless Encryption	Encourage end-user VPN encapsulation and deploy WPA3-OWE (Opportunistic Wireless Encryption).

Case Study 4: DarkHotel Targeted Hotel Wi-Fi Attacks

1. Incident Background & Technical Context

A sophisticated APT campaign targeted C-level executives and defense personnel staying at luxury hotels across Asia by compromising hotel Wi-Fi infrastructure and presenting fake software update prompts (e.g., Adobe Flash, Windows) signed with stolen digital certificates.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Compromised Hotel Network Infrastructure	Inadequate administrative hardening of hotel routers, switches, and gateway servers.
Insecure Captive Portals & Update Channels	Captive portals susceptible to DNS poisoning and HTTP redirection to malicious update payloads.
Weak Code Signing Validation	Target endpoints executing software updates without strict cryptographic verification of digital signatures.
Third-Party Vendor Management Gaps	Unmonitored third-party Wi-Fi service provider access to internal hotel networks.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: Critical. Targeted corporate espionage, theft of intellectual property, trade secrets, and diplomatic communications.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
DNSSEC & Secure DNS	Deploy DNSSEC and DNS-over-HTTPS (DoH) to prevent malicious redirection of update traffic.
Endpoint Application Control	Enforce Endpoint Detection and Response (EDR) with strict code-signing validation and binary whitelisting.
Strict Hotel Guest Network Segmentation	Isolate guest subnets from hotel management networks and implement deep-packet inspection (DPI).

Case Study 5: Marriott Wi-Fi Deauthentication Incident (2014)

1. Incident Background & Technical Context

In 2014, the FCC fined Marriott International \$600,000 after staff at the Gaylord Opryland Resort used Wi-Fi containment equipment to broadcast unauthorized IEEE 802.11 deauthentication frames, forcing conference attendees off personal cellular hotspots to compel purchase of expensive hotel Wi-Fi.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Unprotected 802.11 Management Frames	Legacy 802.11 standards transmit management frames (deauth/disassoc) in plaintext without authentication.
Misconfigured WIPS Containment	Overly aggressive Wireless Intrusion Prevention System rules targeting legitimate external hotspots.

Availability Violation (DoS)	Intentional disruption of radio-frequency communication violating regulatory communications laws.
------------------------------	---

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: High. \$600,000 FCC civil penalty, major brand reputation loss, and legal/regulatory sanctions for intentional RF jamming.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
Mandate 802.11w (PMF)	Enforce Protected Management Frames (PMF / 802.11w) to cryptographically sign deauthentication packets.
WPA3 Transition	Adopt WPA3, which makes Protected Management Frames mandatory across all associations.
WIPS Policy Refinement	Reconfigure WIPS to only alert on rogues inside the corporate domain rather than actively containing external networks.

Case Study 6: Fake Wi-Fi Networks at Republican National Convention (2016)

1. Incident Background & Technical Context

During the 2016 RNC, researchers established benign rogue APs matching common SSID names ('Google Public WiFi', 'RNC Guest') near the venue. Over 1,200 attendees connected automatically, exposing web requests, email headers, and device metadata.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Implicit SSID Trust & Auto-Connect	Mobile operating systems automatically probing and connecting to remembered open SSIDs without validation.
Evil Twin Vulnerability	Open Wi-Fi architecture lacking mutual AP-to-client authentication.
Captive Portal Spoofing	Fake captive portals capable of harvesting credentials and harvesting OAuth tokens.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: Medium to High. Massive credential harvesting, location tracking, and passive surveillance of political and diplomatic delegates.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
Disable Auto-Connect	Configure mobile endpoint policies via MDM to disable auto-join for open networks.
Mandatory Enterprise VPN	Enforce always-on WireGuard/IPsec VPN tunneling with kill-switch mechanisms for mobile devices.
WIDS Rogue SSID Detection	Deploy venue-wide Wireless Intrusion Detection Systems to scan for duplicate and evil-twin SSIDs.

Case Study 7: Wi-Fi Attacks Against Anti-Doping Officials (2016)

1. Incident Background & Technical Context

Russian military intelligence (Fancy Bear / APT28) deployed close-access teams equipped with high-gain directional antennas to hotel parking lots in Rio de Janeiro and Lausanne, compromising Wi-Fi networks to harvest credentials and exfiltrate athlete medical records (ADAMS).

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Untrusted Public/Hotel Wi-Fi	Delegates connecting corporate laptops to unverified hotel wireless infrastructure.
Lack of Phishing-Resistant MFA	Reliance on single-factor passwords or SMS-based authentication for critical medical databases.
Unencrypted Local Storage	Sensitive athlete therapeutic use exemptions (TUEs) stored without hardware-backed full-disk encryption.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: Critical. Compromise of confidential athlete medical records, international reputational fallout, and weaponized data leaks.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
FIDO2 / Hardware Security Keys	Enforce hardware-bound FIDO2/WebAuthn Multi-Factor Authentication across all administrative portals.
Strict Corporate Travel Policy	Provide dedicated cellular 5G mobile hotspots and prohibit connecting to unvetted hotel Wi-Fi.
Zero-Trust Network Access (ZTNA)	Replace legacy perimeter access with context-aware ZTNA verifying device health and certificate posture.

Case Study 8: Attempted OPCW Wi-Fi Intrusion (The Hague, 2018)

1. Incident Background & Technical Context

In April 2018, Dutch MIVD disrupted a close-access cyber operation by GRU operatives parked in a car next to the OPCW headquarters. The vehicle contained directional Wi-Fi antennas, a 4G router, and specialized interception hardware aimed at penetrating the OPCW's internal Wi-Fi network.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
RF Signal Leakage	Internal enterprise Wi-Fi radio frequencies propagating significantly beyond the physical building perimeter.
Potential Weak EAP Validation	Risk of rogue APs capturing MSCHAPv2 challenge-handshakes if endpoints lack strict certificate checking.
Physical Perimeter Vulnerability	Absence of real-time wireless RF boundary monitoring in parking and surrounding zones.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: Critical (Prevented). Attempted sabotage and exfiltration of ongoing chemical weapon investigation findings (e.g., Skripal poisoning).

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
RF Shielding & Power Tuning	Apply RF attenuation window films and dynamically reduce AP transmit power to contain signals within walls.
Strict 802.1X EAP-TLS	Enforce mutual certificate-based 802.1X EAP-TLS; disable fallback to MSCHAPv2 or PEAP without CA validation.
Automated WIPS & Physical RF Patrols	Deploy 24/7 Wireless Intrusion Prevention Systems with RF direction-finding sensors to locate external transmitters.

Case Study 9: Australian Airport and In-Flight Evil-Twin Case (2024)

1. Incident Background & Technical Context

In 2024, the Australian Federal Police arrested an individual who operated portable evil-twin wireless access points at Perth, Melbourne, and Adelaide airports, as well as on domestic flights, serving fake captive portals to steal passenger email and social media credentials.

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
SSID Impersonation (Evil Twin)	Attackers mimicking legitimate airport free Wi-Fi and in-flight airline SSIDs without hindrance.
Deceptive Captive Portals	Cloned login pages prompting users to log in using external Google/Facebook/email credentials.
Bypassing In-Flight Network Trust	Lack of wireless client isolation and AP authenticity checks in confined aircraft cabins.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: High. Mass credential theft, unauthorized access to personal emails and social media, and passenger identity theft.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
Passpoint / Hotspot 2.0 Deployment	Implement Passpoint (Hotspot 2.0) with WPA2/WPA3-Enterprise for seamless, cryptographically verified onboarding.
Airport WIPS Rogue Detection	Deploy automated rogue AP detection in transit hubs to flag identical SSIDs with unauthorized BSSIDs.
Passenger Education & 2FA Enforcement	Alert travelers against entering credentials into unverified captive portals; enforce app-based MFA.

Case Study 10: Network Rail Public Wi-Fi Portal Compromise (2024)

1. Incident Background & Technical Context

On September 25, 2024, public Wi-Fi landing pages across 19 major UK railway stations (including London Euston and Manchester Piccadilly) were defaced to display unauthorized Islamophobic messages after a threat actor hijacked a legitimate administrator account of a third-party supplier (Telent).

2. Technical Vulnerabilities Identified

Vulnerability Domain	Technical Description & Exploitation Mechanism
Privileged Account Compromise	Single administrative account credentials compromised through credential stuffing or phishing.
Missing MFA on Cloud Management Portals	Lack of mandatory hardware-backed MFA for administrative access to the Wi-Fi captive portal CMS.
Inadequate Third-Party Access Governance	Overly broad administrative privileges granted to third-party

	vendor accounts without least-privilege scoping.
Absence of Change Approval Workflows	Direct publishing of landing page changes without multi-party approval or automated content moderation.

3. Risk, Impact & Root-Cause Analysis

Severity & Business Impact: High. Immediate shutdown of public Wi-Fi across nationwide critical infrastructure, public distress, and third-party supply chain exposure.

4. Security Recommendations & Mitigation Measures

Strategic Control	Implementation & Defense-in-Depth Measures
Mandatory Multi-Factor Authentication (MFA)	Enforce phishing-resistant MFA (FIDO2) for all vendor and internal administrative portals.
Privileged Access Management (PAM) & RBAC	Enforce just-in-time access, dual-authorization approval for landing page modifications, and strict RBAC.
Supply Chain Security Auditing	Enforce strict security SLAs and continuous monitoring for third-party Wi-Fi service providers.
Automated Content Verification & SIEM Logging	Implement integrity monitoring on landing pages and real-time SIEM alerts on administrative configuration changes.
